

Recovering a compromised email account

Email accounts are valuable targets for cybercriminals. Not just because they store sensitive messages, but also because they can be used to impersonate the account owner, to spread scams, and to perform password resets. Email account compromise occurs when someone gets unauthorised access to your email account and can act on your behalf. It is important to know the signs that your email account has been compromised and the steps you can take to secure it.

What are the signs that your email account has been compromised?

- You notice changes to your account that you didn't make, such as emails in your inbox marked as read even though you've never opened them.
- There are emails you don't recognise in your deleted or sent folders.
- Emails that you expect to receive don't arrive in your inbox.
- You received an unexpected password reset notification.
- You've been automatically logged out of your account on all devices.
- You can't log in to your account, even though you know the username and password you're using are correct.
- Your contacts tell you they received an unusual or suspicious email from you.
- Your account shows a last login time, location or device that looks wrong.
- Your account provider alerts you to suspicious activity.

Has your business email been compromised?



[Back to top](#)

If it is a business email that you are concerned about, see [what to do if your](#)

[business has been targeted by email fraud or compromise](#).

An account is also compromised if its login details have been leaked, even if there has been no suspicious activity yet. This could happen if you accidentally forget to log out of an account on a public computer, if another account with the same password is compromised, if your login details were in a data breach or if you were tricked into providing your login details as part of a phishing attack. Whatever the cause, you should take the steps listed in this guide to secure your account.

Call if you need support.

The Australian Cyber Security Centre has a 24/7 Hotline: [1300 CYBER1 \(1300 292 371\)](#).

Call now if you need additional support, and in the meantime, keep calm and read this guide. It steps you through what you can do right now to limit the damage.



Step 1. Check that your money is secure

A cybercriminal may be able to use your email account to access your other accounts, including your bank account or accounts that store your credit card. Call your bank or financial institution immediately and ask them to check for suspicious activity. Follow their guidance on securing your account and freezing any affected accounts or cards.

If you are not satisfied with the response from your bank, you can seek free advice from the [Australian Financial Complaints Authority](#).

If you have lost money, do not accept offers from third parties to help you get it back; this is a common tactic used by scammers to steal more money from you.

How could your bank account be at risk?

If a cybercriminal has access to your email account, they may be able to receive password reset requests for your other accounts. They could also use any sensitive information in your emails to impersonate you.

Step 2. Follow the advice from your email provider

After you've confirmed that your money is secure, start to secure your email account. We've listed advice from some popular email providers below. If your email provider is listed, follow the advice on their website.

- [Gmail](#)
- [Outlook](#)
- [Yahoo](#)

You may no longer have access to your account with your old login details. If this is the case, you should search for recovery options offered by your service provider and follow their guidance.

You may not be able to recover your account. If this is the case, you should contact the account provider to let them know your account has been compromised and you no longer have access to it. It is important to still read the steps in this guide. Some steps will not be possible if you cannot log in to your account, but you can still notify contacts and secure other connected accounts.

If your email provider is not listed, you can check their website for advice or follow the standard email account recovery steps below.

Standard email account recovery steps:

Change your password

Change your password or passphrase. It is best practise to change your password or passphrase by logging into your email account's online platform or application directly. Avoid clicking on password or passphrase reset links you receive by email or message because fake reset links are commonly sent by cybercriminals. The ACSC has published [guidance on using password managers](#) and [creating unique passphrases](#), a strong type of password. If you cannot access your account to change your password or passphrase, check if the email provider has an account recovery option. Note, in some cases, email providers may take a number of days to conduct additional checks before facilitating access to your account.

Check your account recovery options

Go to your account settings and check that your account recovery details are accurate and up-to-date. Remove any account recovery options you don't recognise. Cybercriminals sometimes add account recovery options that let them regain access to your account.

Log out of all devices.

You may be able to manage what devices are logged into the account. If your account has this option, log out of all devices. You can usually find this option on your account security settings page. Changing your password or passphrase should also automatically log you out of all other devices.

Enable multi-factor authentication

Enable multi-factor authentication, if your account provider offers it. Multi-factor authentication will make it harder for cybercriminals to gain access to your account again. The ACSC has published guidance on [enabling multi-factor authentication](#). The cybercriminal may have added their own multi-factor authentication methods, so remove any you don't recognise.

Check your email forwarding rules

Cybercriminals will often set up rules to forward incoming emails to other accounts so they can read them, even after you change your password. Remove any email forwarding rules you do not recognise.

Check your automatic replies

Cybercriminals may set up automatic replies to further spread malicious content. Check your account's automatic reply rules and remove any you do not recognise.

Step 3. Secure connected accounts

If a cybercriminal has access to your email account, they might have access to your other accounts too. Look for suspicious activity on your other accounts, starting with the most important ones. Prioritise accounts that have access to your finances (such as your bank account or online shopping accounts) or sensitive information (such as business, or cloud storage accounts). Accounts to look out for are:

- **Accounts that share the same password as your email account.**

Change any shared passwords or passphrases to unique ones. The ACSC has published

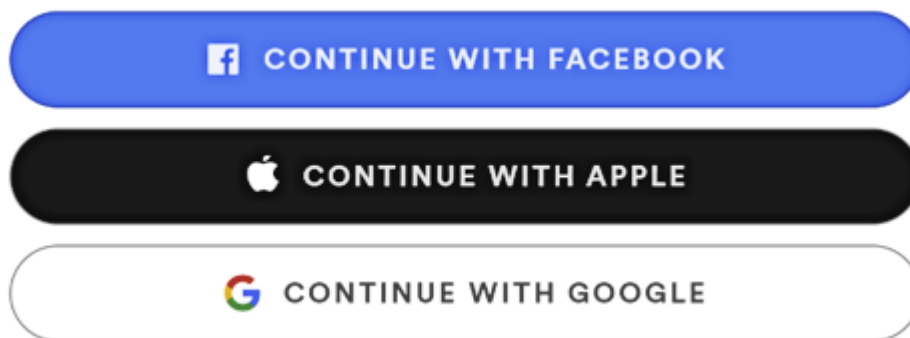
[advice on using password managers](#) and [creating unique passphrases](#), a strong type of password.

- **Accounts that use your email as a password recovery option.**

Have you ever nominated this email address as the password recovery option for another account? If so, your other account may be at risk, check it for suspicious activity as a priority

- **Accounts that use your email as a third party authenticator.**

For example, if your Gmail account has been compromised, you should check for unauthorised activity on any other account where you used the "sign in with Google" or "continue with Google" option.



Step 4. Check for suspicious activity

As you are securing your accounts, remain on the lookout for suspicious activity. Check your email folders to see if emails have been sent, opened, or deleted without your knowledge. Pay particular attention to your sent emails folder and deleted emails folder.

Be aware that the person who accessed your account may have hidden their activity, for example, by permanently deleting emails or marking emails they opened as 'unread'. Your account provider may have an option to recover emails that were recently deleted. Knowing what unauthorised emails have been sent will be important for the next step.

Step 5. Notify your contacts

If you noticed messages sent in the last step, you should inform any affected contacts that unauthorised messages have been sent in your name. This will help them recognise suspicious activity and disregard fraudulent emails. There's a template below that you can use to notify your contacts.

To <insert name>

My email account has been the target of fraudulent cybercriminal activity.

I became aware on <insert date> that a cybercriminal sent emails to my contacts impersonating me. These emails may have been related to <insert details you may have noticed about sent emails such as phishing for account details or personal information, asking for money, or anything else suspicious>. The emails were sent by the following address: <insert compromised email address>.

If you received an email from me that matches this description, please ignore the email's contents and let me know.

Sincerely

<Your name>

Step 6. Secure your device

Do you know how your account was initially compromised?

If you don't, cybercriminals may have used malware to steal the username and password for your account. Refer to the ACSC's guidance on [removing malware](#)

Step 7. Report the incident

Make a record of the key details of the incident, including details of what happened, when it happened, what you think may have led to the incident, and the steps you took in response. Using your record, report the incident to the appropriate authorities:

- Use [ReportCyber](#) to report the incident to the ACSC and the relevant police jurisdiction.
- If the cybercriminal used a scam to access your account, or if they used your account to scam other people, report the incident to [Scamwatch](#).
- Report the incident to your account provider, for example, Outlook, Yahoo, or Google.

Step 8. Prevent future attacks

[Read the ACSC's advice on preventing cybercriminals from getting access to your accounts.](#)